

Vulnerability & Patch Management

Purpose

Describe how vulnerabilities are identified, prioritized, and remediated for the Personal Finances application.

Asset scope

- Developer workstation (single admin laptop)
- Production runtime (hosting provider environment)
- Application dependencies (Node.js/NPM packages)
- Database (managed PostgreSQL)

Dependency scanning

- NPM advisory scanning is run via `npm audit`.
- Dependency updates are applied regularly (at least monthly) and sooner for high/critical vulnerabilities.

Patching cadence

- Operating system and browser updates are applied promptly on the developer workstation.
- Application dependencies are updated on a regular cadence and after relevant advisories.

Remediation targets

- Critical vulnerabilities affecting exposed services: patch/mitigate as soon as practical (target within 48 hours).
- High severity: patch/mitigate promptly (target within 7 days).

Secure configuration

- Secrets are provided via environment variables / secret manager.
- Production configuration is reviewed before deployment (CORS origins, JWT secret length, Plaid credentials present).

Change control (lightweight)

- Changes are tracked in source control.
- Security-impacting changes (auth, secrets, Plaid integration) are reviewed by the developer before deployment.